

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-07-05 · Source SHA: 61ed8c3140d76e3a19a88954e834d39c9f7635fb · Model: 0.5·CVE + 0.3·exposure + 0.2·criticality

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0, Log4Shell)	2.17.1
2	log4j-api	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1
3	jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8) + 3 more	2.13.4.2
—	com.fastxml...:jackson-databind	2.9.8	CRITICAL	—	Typosquat, unresolvable (REMOVE)	remove
4	guava	24.1.1-jre	HIGH	6.0	CVE-2018-10237 (5.9) + 2 more	32.0.0-jre
5	commons-lang3	3.4	MEDIUM	5.2	CVE-2025-48924 (5.3, new)	3.18.0
6	commons-io	2.4	MEDIUM	4.9	CVE-2021-29425 (4.8)	2.7
7	mysql-connector-java	8.0.30	LOW	2.8	GPL-2.0-with-FOSS-exception license VIOLATION	8.0.33 (license unresolved)
8	junit-jupiter	5.10.2	LOW	1.7	test-scope, outdated only	6.1.1

Remaining 15 transitive dependencies (jackson-core/annotations, protobuf-java, guava's annotation libs, JUnit platform modules, etc.) all scored **LOW** (risk 1.1–2.2) — no CVEs matched and no located usage in application code.

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0 (located: used in DiscountCalculator)	7.8
log4j-api	10.0	8.0	2.0 (located)	7.8
jackson-databind	10.0	8.0	2.0 (default — no usage located)	7.8
guava	6.9	7.0	2.0 (default)	6.0
commons-lang3	5.3	7.0	2.0 (default)	5.2
commons-io	4.8	7.0	2.0 (default)	4.9
mysql-connector-java	0.0	8.0	2.0 (default)	2.8

Note: no CRITICAL-banded row appears despite three CRITICAL-severity CVEs (CVSS ≥ 9.0) because the weighted formula discounts a max CVE score of 10.0 by exposure/criticality; the pipeline's floor rule (any CRITICAL CVE → band ≥ HIGH) is already satisfied by these rows' natural HIGH score.

Priority recommendations

1. **P0** — Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` coordinate (supply-chain; currently blocks all dependency resolution).
2. **P0** — Upgrade `org.apache.logging.log4j:log4j-core / log4j-api` 2.14.1 → 2.17.1 (Log4Shell, actively exploited in the wild).
3. **P1** — Upgrade `com.fasterxml.jackson.core:jackson-databind` 2.9.8 → 2.13.4.2+ (4 CVEs, 2 critical RCE-capable deserialization chains).
4. **P1** — Upgrade `com.google.guava:guava` 24.1.1-jre → 32.0.0-jre or later (major bump — review for API breakage).
5. **P2** — Upgrade `org.apache.commons:commons-lang3` 3.4 → 3.18.0+ (newly disclosed CVE-2025-48924).
6. **P2** — Upgrade `commons-io:commons-io` 2.4 → 2.7+ (patch to at least 2.7; latest 2.22.0 available).
7. **P2** — Resolve `mysql:mysql-connector-java` GPL-2.0-with-FOSS-exception license policy violation (swap driver or obtain legal exception) and bump to 8.0.33.
8. **P3** — Routine major-version bump: `junit-jupiter` 5.10.2 → 6.1.1 (test-scope, low urgency).

Machine-readable source: `depscan-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.